

[Learner Login »](#) [Learner Support »](#)

**25% off all training courses**

[View HIPAA Courses](#)

*Offer ends June 26, 2026*



[Become HIPAA Compliant »](#) [HIPAA Checklist](#) [HIPAA News »](#)

[HIPAA Breach News »](#) [Cybersecurity News »](#) [HIPAA Legal News »](#) [About »](#)

## HIPAA Training Requirements

Posted By [Steve Alder](#) on Feb 15, 2026

The HIPAA training requirements are that "a covered entity must train all members of its workforce on policies and procedures [...] as necessary and appropriate for the members of the workforce to carry out their functions within the covered entity" ([§164.530\(b\)\(1\)](#) of the HIPAA Privacy Rule). A covered entity or business associate must "implement a security awareness and training program for all members of its workforce including management". ([§164.308\(a\)\(5\)](#) of the HIPAA Security Rule).

### Table of Contents

- ▶ [What are the HIPAA Training Requirements?](#)
- ▶ [How Often is HIPAA Training Required?](#)
- ▶ [What Should be Included in a HIPAA Training Course?](#)
- ▶ [Additional HIPAA Training Required for New Technologies](#)
- ▶ [Best Practices for HIPAA Compliance Training](#)
- ▶ [Additional State Medical Privacy Law Training](#)
- ▶ [Targeted HIPAA Training](#)
- ▶ [HIPAA Training for Employees](#)
- ▶ [HIPAA Training for Business Associate Staff](#)
- ▶ [HIPAA Compliance Training for Students](#)
- ▶ [HIPAA Training for IT Professionals](#)
- ▶ [HIPAA Training for Small Medical Practice Employees](#)
- ▶ [HIPAA Training for Medical Office Staff](#)
- ▶ [HIPAA Refresher Training](#)
- ▶ [HIPAA Training Requirements FAQ](#)

## What are the HIPAA Training Requirements?

The HIPAA training requirements apply to any individual or organization with access to Protected Health Information (PHI) that perform a regulated activity as a covered entity or as a business associate. HIPAA's training requirements don't apply only to covered entities. The Administrative Simplification Regulations (§160.102) make it clear that when a business associate has to follow a HIPAA Privacy Rule standard in order to do its job for a covered entity, it has to meet the same training requirement.

In practice, that means a business associate providing a service for or on behalf of a covered entity has to train its workforce on all applicable HIPAA Privacy Rule standards, just like a covered entity would. And when it comes to the HIPAA Security Rule, the expectation is even broader: both covered entities and business associates must train everyone on their workforce, whether they work directly with PHI or not.

## HIPAA Training That Lowers Breach Risk

Our training goes beyond basic rule coverage by targeting the mistakes that drive most incidents, using real-world, relatable examples drawn from over 10 years of our HIPAA breach reporting.

[View Training](#)

The Gold Standard in HIPAA Training  
by The HIPAA Journal Team

[HIPAA Training for Individuals](#)

## HIPAA Training That Lowers Breach Risk

Our training goes beyond basic rule coverage by targeting the mistakes that drive most incidents, using real-world, relatable examples drawn from over 10 years of our HIPAA breach reporting.

[View Training](#)[See Team Pricing](#)[Talk To Us](#)

The Gold Standard in HIPAA Training by The HIPAA Journal Team

Lessons Cover Emerging Issues Like AI Tools | CEUs & Certificate | Completion Tracking | [HIPAA Training for Individuals](#)

### The HIPAA Privacy Rule Training Standard

The HIPAA Privacy Rule training standard is tied directly to the rule's broader expectation that organizations build and follow policies and procedures that reflect how they handle PHI. The Administrative Requirements of the HIPAA Privacy Rule lay this out clearly:

*"A covered entity must implement policies and procedures with respect to protected health information that are designed to comply with the standards, implementation specifications, or other requirements of this subpart [the [HIPAA Privacy Rule](#)] and subpart D of this part [the [Breach Notification Rule](#)]. The policies and procedures must be reasonably designed, taking into account the size and the type of activities that relate to protected health information undertaken by a covered entity, to ensure such compliance."*

This means covered entities, and business associates when the rule applies to them, must establish policies and procedures for every part of their operations that involves PHI. That includes routine uses and disclosures, as well as how the organization responds when something goes wrong.

Once those policies and procedures exist, the training requirement follows. The HIPAA Privacy Rule Administrative Requirements state:

*"A covered entity must train all members of its workforce on the policies and procedures with respect to protected health information required by this subpart and subpart D of this part, as necessary and appropriate for the members of the workforce to carry out their functions within the covered entity."*

### The HIPAA Security Rule Training Standard

The HIPAA Security Rule training requirement is often perceived as simpler to comply with than the HIPAA Privacy Rule training standard, but the perceived simplicity can be misleading. The standard states

*"Implement a security awareness and training program for all members of its workforce (including management)."*

HHS offers additional direction through four addressable implementation specifications:

1. Periodic security updates.
2. Procedures for guarding against, detecting, and reporting malware.
3. Procedures for monitoring login attempts and reporting discrepancies.
4. Procedures for creating, changing, and safeguarding passwords.

These elements form the baseline for a security awareness program. But the placement of the training requirement within the Administrative Safeguards (§164.308) adds an important layer. The section begins with:

"A covered entity or business associate must, in accordance with §164.306."

Section §164.306 outlines the General Requirements of the HIPAA Security Rule, including the obligation to protect against any reasonably anticipated uses or disclosures not permitted under the HIPAA Privacy Rule. In other words, the HIPAA Security Rule is not limited to cybersecurity mechanics. It is tied directly to the protection of PHI, and that connection is often overlooked.

When organizations treat Security Rule training as purely technical, such as malware, passwords, login monitoring, they leave significant gaps. A workforce can know how to spot a phishing email and still violate HIPAA by exporting a PHI database and emailing it to themselves. Technical controls matter, but they do not replace an understanding of how PHI must be used, disclosed, and safeguarded under the HIPAA Privacy Rule.

Effective HIPAA security awareness training keeps PHI as the focus and is designed for healthcare staff. Cybersecurity concepts are taught in the context of PHI protection, not as standalone IT hygiene. Organizations that integrate HIPAA Privacy Rule concepts into their HIPAA Security Rule training deliver a more accurate and complete program. The HIPAA Journal's [CyberSecurity Training for Healthcare Employees](#) has been designed to satisfy the HIPAA Security Rule training requirements.

### How Often is HIPAA Training Required?

The HIPAA Privacy Rule Administrative Requirements make the timing of HIPAA training clear. Training must be provided to "each new member of the workforce within a reasonable period of time after the person joins the covered entity's workforce" and again when "functions are affected by a material change in policies or procedures," also within a reasonable period. In practice, new staff should be trained as soon as possible, and most healthcare organizations treat annual refresher training as the standard.

The HIPAA Security Rule adds another layer. Its training requirement implies that security awareness programs should be continuous, not one-off events. Training should be updated whenever working practices or technology change, when a risk assessment identifies a gap, or when HHS issues new rules or guidance. To stay ahead of these triggers, HIPAA Privacy and Security Officers should:

- Monitor HHS and state publications for advance notice of rule changes, ideally through official alerts or news feeds.
- Conduct a risk assessment whenever new rules or guidance are released to determine whether training needs to be updated.
- Coordinate with HR and Practice Managers to understand upcoming operational changes that may affect HIPAA Privacy Rule compliance.
- Coordinate with IT leadership to anticipate hardware or software changes that may affect HIPAA Security Rule compliance.
- Perform regular risk assessments to identify how changes in policies or procedures may increase or reduce the risk of violations.
- Build training that explains how changes affect day-to-day compliance, not just the changes themselves.
- Maintain a refresher training program that can be delivered at least annually when no other training triggers occur.

HIPAA training does not need to be delivered to every workforce member every time something changes. Only those whose roles are affected need updated instruction. Even so, including at least one senior leader in training sessions is a smart practice. It signals organizational commitment and reinforces that compliance is not just an operational task, it's a leadership responsibility.

One challenge for HIPAA-Covered Entities with the "reasonable period" standard is that long gaps can develop when nothing material changes. If refresher training is only delivered "periodically," staff can drift into shortcuts or workarounds that undermine compliance. This is why annual HIPAA training remains the norm across the healthcare sector: it keeps expectations fresh and reduces the risk of avoidable violations.

---

## HIPAA Training for Business Associates

---

Our training includes specific lessons covering the unique HIPAA-challenges faced by staff at Business Associates.

[View Training](#)

The Gold Standard in HIPAA Training  
by The HIPAA Journal Team

[HIPAA Training for Individuals](#)

## HIPAA Training for Business Associates

Our training includes specific lessons covering the unique HIPAA-challenges faced by staff at Business Associates.

[View Training](#)[See Team Pricing](#)[Talk To Us](#)

The Gold Standard in HIPAA Training by The HIPAA Journal Team

Lessons Cover Emerging Issues Like AI Tools | CEUs & Certificate | Completion Tracking | [HIPAA Training for Individuals](#)

### What Should be Included in a HIPAA Training Course?

The core elements of a HIPAA training course work well as an introduction to HIPAA and can also serve as the foundation for annual refresher training.

### Recommended Content for HIPAA Compliance Training

#### The Role of the HIPAA Compliance Officers

This module should cover the roles of HIPAA Compliance Officers, HIPAA Privacy Officers, and HIPAA Security Officers, when to contact them, and how to use official reporting channels. This training is important for staff who have never worked in a HIPAA-Covered Entity or HIPAA Business Associate, including healthcare students on clinical placement, because it clarifies the central role of the HIPAA officers in the compliance process. The module should be optional for staff who have already worked in healthcare and understand the compliance officer's role.

#### Definitions and Lexicons

This module should provide definitions of frequently used "HIPAA terms" such as PHI, ePHI, Minimum Necessary, Covered Entity, Business Associate, and Healthcare Operations. The module should be available for all staff but can be optional for staff who have already worked in healthcare and understand HIPAA terminology.

#### The Main HIPAA Regulatory Rules

This module should give an overview of the HIPAA Privacy Rule, HIPAA Security Rule, and HIPAA Breach Notification Rule with details of how they affect daily workflows. The module must include practical examples that turn regulatory theory into practical advice.

#### HIPAA Compliance for Staff

This module should explain why workforce members are responsible for maintaining their HIPAA knowledge and compliance. The module should focus on how and why staff should take personal responsibility for HIPAA compliance.

#### Why HIPAA Compliance is Important

This module should explain why HIPAA compliance matters for workforce members, for the organization, and for patients/plan members. The main objective of this module is to explain the positive impact of protecting patient privacy. This module can be optional for experienced staff but is important for new staff who have not previously worked in healthcare.

#### The Consequences of HIPAA Violations and Breaches

This module should focus on the real consequences of HIPAA violations and data breaches and how these events affect workforce members, organizations, and patients.

#### Preventing HIPAA Violations

This module should cover common error patterns and offer practical habits to avoid them, including mindful, permitted disclosures.

#### PHI Disclosure Guidelines

This module should explain the difference between required and permitted disclosures and address situation-specific scenarios in which

disclosures may be permitted.

### **HIPAA Rights for Patients**

This module should cover patient rights (access, amendments, restrictions, confidential communications, accounting of disclosures, etc.) and how to route requests correctly.

### **HIPAA Security Rule and Threats to Patient Data**

This module should explain the four types of threats to patient data and how workforce members can support an organization's efforts to defend against them.

### **HIPAA Security Rule and Protecting Electronic PHI**

This module should cover everyday steps workforce members can take to protect electronic PHI and explain how to escalate security incidents when they occur.

### **HIPAA and Emergency Situations**

This module should explain what disclosures of PHI are permitted during medical, manmade, and physical emergencies, or when there is a risk of imminent danger. This module is typically optional for most staff, except staff who work in emergency services or emergency rooms.

### **Recent HIPAA Updates**

This module should include summaries of recent and proposed changes, workflow impacts, and practical cautions to avoid impermissible disclosures.

## **Additional HIPAA Training Required for New Technologies**

### **HIPAA Training for Email, Messaging, and Texting**

This training must cover using only approved, secure channels for PHI; applying the Minimum Necessary standard; verifying identity before sending; and documenting disclosures per policy. It must teach employees how to craft message content (no PHI in subject lines, limited details in voicemails/texts), handle misdirected messages (immediate recall/notification and escalation), and use safeguards such as encryption, access controls, and auto-lock on mobile devices. It is a requirement that email systems and texting systems must be HIPAA-compliant.

### **HIPAA Training for Social Media**

This training must explain how casual posts, photos, or "anonymous" case descriptions can disclose PHI and trigger sanctions. It should reinforce that once content is online, employees lose control of further disclosure or manipulation. Work stories, images from clinical areas, and patient details (even without names) are risky. The module should reinforce a culture of caution: follow organizational policy, avoid posting about patients or workplaces, and consult the [HIPAA Compliance Officer](#) when unsure.

### **HIPAA Training for Artificial Intelligence (AI) Tools**

This training must explain which AI tools are approved for use in the organization, how they are configured, and how unapproved or untrained AI tools can lead to impermissible disclosures or violate the HIPAA Minimum Necessary Rule. It should cover best practices: never paste PHI into non-approved AI tools, validate AI outputs before use, log interactions when required, and report anomalies or inaccurate results. It should also make clear that employees should not rely on AI tools to answer HIPAA compliance questions, as these tools may be inaccurate or out of date.

## **Best Practices for HIPAA Compliance Training**

Because HIPAA doesn't spell out detailed training requirements, compliance managers have to determine what is "necessary and appropriate" for onboarding, security awareness, and refresher programs. The following best practices can help shape effective, defensible training. They can be adapted to fit the needs of each organization.

- **Do** test trainees during the training because self-attestation is not reliable. Staff will stay more engaged when they know they will be tested, and testing provides evidence that the material was actually learned.
- **Do** cover all required elements. Skipping topics to save time is a false economy. Gaps in training almost always lead to HIPAA violations or HIPAA breaches that cost more than the time saved.
- **Do** include the consequences of a HIPAA breach beyond organizational penalties. Workforce members need to understand personal impacts of disciplinary actions and operational interruptions, and the harm to patients whose PHI is exposed.
- **Do** provide Continuing Education Units (CEUs). CEUs motivate workforce members to complete training and reinforce that the organization values professional development. Use HIPAA training programs that offer CEUs.
- **Don't** quote long passages of text from HIPAA regulations. Quoting large blocks of text from guidebooks or the regulations is rarely effective. Workforce members need HIPAA training they can understand, absorb, and apply in daily work.

- **Do** include senior management in the training. Even if senior managers have no contact with PHI, their presence signals HIPAA compliance is a priority. When leadership takes HIPAA training seriously, the rest of the workforce is more inclined to follow.
- **Don't** forget to document your training. If OCR investigates or audits, you must be able to show what training was delivered, when, to whom, and how often. If you're not using an LMS, trainees should sign attestations confirming completion.
- **Do** provide comprehensive security awareness training that combines HIPAA compliance training and general online security training. Cover best practices such as using a password manager, reducing phishing susceptibility, and backing up data. This will help build a security culture in the organization.

### Additional State Medical Privacy Law Training

State medical privacy laws often add to HIPAA by imposing stricter or supplemental obligations on workforce members. In these states, staff must follow HIPAA plus any stricter state rule such as tighter consent requirements, shorter response timelines, expanded breach-notification content, or added safeguards for automated tools. Because of this, HIPAA training in certain states must also include the relevant state-specific privacy requirements

### Texas Medical Privacy and Data Security Laws

In Texas, obligations can exceed HIPAA under the Texas Medical Records Privacy Act (as amended by HB 300). Additional duties are shaped by the Texas Identity Theft Enforcement and Protection Act, the Texas Data Privacy and Security Act, and AI-related measures such as the Texas Responsible AI Governance Act and SB 1188 on AI and electronic health records.

### California Medical and Data Privacy Laws

California adds its own layers of protection through the Confidentiality of Medical Information Act, the Patient Access to Health Records Act, Medi-Cal rules, and the California Consumer Privacy Act/Privacy Rights Act (including automated decision-making provisions). New requirements also appear in Health and Safety Code provisions added by SB 81 (Patient Access and Protection).

### Additional Federal Laws

HIPAA applies to covered entities and business associates, but it is not the only federal law governing health information. HIPAA sets minimum standards, and in some situations other federal or state laws preempt it. For example, federal agencies must comply with the Privacy Act, and public teaching institutions must comply with FERPA.

## Targeted HIPAA Training

### HIPAA Training Requirements for Employers

The HIPAA training requirements for employers only apply to employers that are HIPAA covered entities or business associates (in most cases). Employers that fall into these categories must provide HIPAA training to all members of the workforce, regardless of role, as required by the Administrative Safeguards of the HIPAA Security Rule. Sometimes contractors that are not HIPAA Business Associates are still required by healthcare providers to have HIPAA training, with [HIPAA certification for medical couriers](#) a good example. If an employer is not a covered entity or a business associate but engages in HIPAA-covered transactions (for example, the employer administers a self-insured health plan), HIPAA training only needs to be provided to employees with access to PHI or ePHI. Further information about HIPAA training requirements for employers in these circumstances can be found [in this article](#).

## HIPAA Training for Employees

In addition to providing "necessary and appropriate" HIPAA training for employees, it helps to offer additional training that gives context to what each employee learns. For example, when covering the HIPAA rules for PHI disclosures, it is useful to also discuss the consequences of HIPAA violations.

HIPAA requires organizations to document the training provided to employees. This has practical advantages: if material changes to policies or procedures occur and they affect only a specific area of HIPAA compliance, documentation makes it clear who has already been trained in that area and who now needs refresher training.

### HIPAA Training That Lowers Breach Risk

Our training goes beyond basic rule coverage by targeting the mistakes that drive most incidents, using real-world, relatable examples drawn from over 10 years of our HIPAA breach reporting.

[View Training](#)

The Gold Standard in HIPAA Training  
by The HIPAA Journal Team

[HIPAA Training for Individuals](#)

### HIPAA Training That Lowers Breach Risk

Our training goes beyond basic rule coverage by targeting the mistakes that drive most incidents, using real-world, relatable examples drawn from over 10 years of our HIPAA breach reporting.

[View Training](#)

[See Team Pricing](#)

[Talk To Us](#)

The Gold Standard in HIPAA Training by The HIPAA Journal Team

Lessons Cover Emerging Issues Like AI Tools | CEUs & Certificate | Completion Tracking | [HIPAA Training for Individuals](#)

## HIPAA Training for Business Associate Staff

The HIPAA training requirements for business associates are often misunderstood because, notwithstanding the Applicability standard §160.102, nowhere in the HIPAA Privacy Rule does it state HIPAA training for business associates is mandatory. However, the Administrative Safeguards of the HIPAA Security Rule (45 CFR §164.308) state:

"A covered entity or business associate must ... implement a security awareness and training program for all members of its workforce

(including management)."

While this could be read as a general security awareness requirement rather than HIPAA-specific training, it makes practical sense for the training to be HIPAA-related. If a HIPAA violation occurs and there is no evidence that appropriate business associate training was provided, regulators are far more likely to treat the lapse as willful neglect.

As a result, although business associates must comply with the HIPAA Security Rule's requirement for a security awareness and training program, it is wise to train workforce members on the parts of the Administrative Requirements, the HIPAA Privacy Rule, and the HIPAA Breach Notification Rule that apply to their roles or that are required under a Business Associate Agreement.

Business associate staff need HIPAA training because the HIPAA Privacy Rule can apply to their work in addition to standard security awareness. This training explains the roles of covered entities, business associates, and subcontractors, and how PHI moves along the chain of custody so employees understand their place in the workflow. It clarifies responsibilities under the HIPAA Security Rule, the purpose of safeguards, what a Business Associate Agreement (BAA) permits, and when to alert Security or Privacy Officers about a security incident. Employees learn the limits on uses and disclosures tied to the BAA and the service they provide, the Minimum Necessary standard for access, and the steps to take if PHI is exposed. The program also sets expectations about consequences, sanctions, patient harm, and organizational costs, using case studies to keep compliance front of mind.

### HIPAA Compliance Training for Students

The HIPAA Privacy Rule states that HIPAA compliance training should be provided to new employees "within a reasonable period of time of a new employee joining a covered entity's workforce." While there may be valid reasons not to train a new employee before they access PHI if, for example, they recently transferred from another healthcare facility and already understand HIPAA, that exception does not apply to healthcare students. HIPAA training for students differs from regular training because students need additional guidance on topics that do not apply to most healthcare professionals, such as using PHI in assignments.

Healthcare students should receive HIPAA training before they access PHI so they understand disclosure guidelines when they begin working with patients or using healthcare data for reports and projects. An appropriate HIPAA training course for students would include the core elements listed above, plus additional content relevant to their education.

### Electronic Health Record Access by Healthcare Students

During their training, students may be allowed to access EHRs under supervision. They need to know what they can and cannot do with patient PHI under HIPAA, and that using someone else's login credentials to access PHI is a violation.

### PHI & Student Reports and Projects

Students need to be aware that when writing reports, preparing case studies, or giving presentations, they cannot use PHI unless the patient has given their informed authorization, or unless PHI is de-identified by removing all identifiers that make the health information "protected".

### Being a HIPAA Compliant Student

Students are responsible for understanding the covered entity's HIPAA policies and procedures and following them just as a healthcare professional would. They also need to know how to recognize a HIPAA violation and who to report it to.

## HIPAA Training for Small Medical Practices

Our training includes specific lessons covering the unique HIPAA-challenges that can arise in small medical practices

[View Training](#)

The Gold Standard in HIPAA Training  
by The HIPAA Journal Team

[HIPAA Training for Individuals](#)



## HIPAA Training for Small Medical Practices

Our training includes specific lessons covering the unique HIPAA-challenges that can arise in small medical practices

[View Training](#)

[See Team Pricing](#)

[Talk To Us](#)

The Gold Standard in HIPAA Training by The HIPAA Journal Team

Lessons Cover Emerging Issues Like AI Tools | CEUs & Certificate | Completion Tracking | [HIPAA Training for Individuals](#)

### HIPAA Training for Small Medical Practice Employees

Small medical practices face circumstances that differ from larger healthcare facilities. HIPAA training for small practice staff should prepare employees for real-world constraints: tight workspaces, multitasking at a busy front desk, unfamiliar software, and working in close-knit communities where people may ask about neighbors' health.

Training must teach employees how to control the physical environment (screen privacy, clean desks, locked bins), manage interruptions without over-sharing, and use only approved systems for PHI. It should explain why copying shortcuts from others is risky, provide simple technical steps (strong passwords, MFA, logging out), and offer scripts to help resist community pressure ("I can't discuss patient information"). Employees also need to understand the difference between a violation and a breach, how to report incidents quickly, and the potential sanctions or external penalties that can follow.

### HIPAA Training for IT Professionals

While it is natural to assume HIPAA training for IT professionals should focus on IT security and protecting networks against unauthorized access, it is also important IT professionals receive training about the challenges experienced by frontline healthcare professionals when trying to comply with HIPAA.

This helps IT teams design systems and procedures that support, rather than hinder, clinical workflows. When systems are too complicated or appear irrelevant to someone's role, staff will find workarounds, which can put ePHI at risk of exposure, loss, or theft.

### HIPAA Training for Medical Office Staff

Depending on the size of the office and the range of roles, HIPAA training for medical office staff is often more comprehensive than for many other categories of healthcare employees. Medical office teams may interact with patients, family members, third-party requestors, suppliers, payment processors, and health plans.

Because the scenarios they encounter are so varied, HIPAA training needs to be memorable and applicable to daily work. The more contextual the training, the better. This helps employees understand why HIPAA matters and why protecting ePHI is important.

## HIPAA Refresher Training

HIPAA refresher training should be delivered regularly so non-compliant habits don't become part of the workplace culture. It should also be provided whenever new threats to patient data are identified. Employees need to know how to recognize these threats and respond appropriately, and waiting for an annual refresher could leave the organization exposed to an avoidable breach.

In addition to covering changes to policies and procedures, refresher training should revisit core concepts from time to time. Employees need reminders about why HIPAA matters and what patients' rights are, especially as proposed [changes to the HIPAA Privacy Rule](#) aim to improve data sharing and interoperability.

## HIPAA Training Requirements FAQ

### What is HIPAA training?

HIPAA training is part of the training new members of a covered entity's workforce receive when they start working for a covered health plan, healthcare clearinghouse, healthcare provider, or pharmacy. The training should include an explanation of terms such as Protected Health Information and why it is necessary to protect the privacy of individually identifiable health information.

HIPAA training should also include security awareness topics such as password management and phishing awareness. This element of training should not only be provided for members of a covered entity's workforce, but also to members of a business associate's workforce regardless of the access to electronic Protected Health Information.

### How long is HIPAA training good for?

HIPAA training is good for one year because best practice in the healthcare sector is to provide annual HIPAA training.

There are circumstances where additional HIPAA training is required, such as when new regulations are published, when members of the workforce are required to undergo HIPAA refresher training due to an internal policy change, when an employee receives a sanction for a non-compliant event, or when there is a Corrective Action Plan imposed by HHS.

As well as policy and procedure training, the HIPAA Security Rule stipulates that all members of the workforce are required to participate in a security awareness and training program. As the use of the term "program" implies security and awareness training is ongoing, HIPAA training of this nature has no specific expiry date. It is necessary to continue improving the workforce's resilience against online threats.

### How can you get HIPAA training?

You get HIPAA training from your employer when you start working for a business required to comply with the HIPAA Privacy, Security, and/or HIPAA Breach Notification Rules. If you have no previous knowledge of HIPAA, it can be beneficial to invest in an online HIPAA training course to better understand the basics of HIPAA before moving onto policy and procedure training.

### When must new employees complete their HIPAA training?

New employees must complete their HIPAA training "within a reasonable period of time" according to the HIPAA Privacy Rule. Some states and some organizations have fixed time limits. For example, new employees in Texas must complete their HIPAA training within 90 days, while personnel attached to the Defense Health Agency must complete their training within 30 days.

### How often should HIPAA training be completed?

HIPAA training should be completed as often as is necessary to mitigate the risk of a HIPAA violation or data breach. For some members of the workforce, this may mean completing HIPAA training monthly or quarterly; while, for other members of the workforce, annual refresher training is often sufficient to maintain compliance.

### Is there a difference between HIPAA compliance training and other types of HIPAA training?

Although there is no official difference between HIPAA compliance training and other types of HIPAA training, some organizations refer to policy and procedure training as HIPAA compliance training while HIPAA rules and regulations training (i.e., security and awareness training) is referred to as HIPAA training. The HIPAA Journal has designed its HIPAA training to provide comprehensive training on HIPAA rules and regulations.

### How often do healthcare workers need to have HIPAA training?

Healthcare workers need to have HIPAA training as often as required to perform their roles in compliance with the HIPAA Privacy, Security, and HIPAA Breach Notification Rules. Many healthcare workers only have HIPAA training when they start working for a new employer and when there is a material change to policies and procedures, and this is often not enough to ensure compliance.

### How long must HIPAA security awareness training documents be maintained?

HIPAA security awareness training documents must be maintained for as long as policies or procedures related to the training (including sanctions policies) are in force plus six years. This is because documentation relating to policies and procedures have to be maintained for six years from the date they are last in force and, if training is based around the policies and procedures, the documents relating to the training must also be maintained for the same period of time.

### How often does CMS require HIPAA training?

Although the Centers for Medicare and Medicaid Services (CMS) regulates compliance with Part 162 of HIPAA (relating to the operating rules for transactions, code sets, identifiers, etc.), CMS does not require HIPAA training. The agency does provide a series of web-based training courses on the [Medicare Learning Network](#) which cover a broad range of topics related to Part 162 compliance.

### Who is in charge of HIPAA training?

The individual in charge of HIPAA training is the Privacy Officer or the Security Officer depending on whether the training relates to HIPAA policies and procedures or security and awareness training. Although in charge of training, neither Officer has to be present during a training session if – for example – a member of the IT team is demonstrating how a software solution works.

### HIPAA requires specific training on what?

HIPAA requires specific training on the policies and procedures developed by the organization to protect the privacy of individually identifiable health information. Members of the workforce do not have to receive training on every policy and procedure – just those that are relevant to their roles (although it is also a good idea to provide general HIPAA training to all members of the workforce).

---

## HIPAA Training That Lowers Breach Risk

---

Our training goes beyond basic rule coverage by targeting the mistakes that drive most incidents, using real-world, relatable examples drawn from over 10 years of our HIPAA breach reporting.

[View Training](#)

**The Gold Standard in HIPAA Training**  
by The HIPAA Journal Team

---

[HIPAA Training for Individuals](#)

## HIPAA Training That Lowers Breach Risk

Our training goes beyond basic rule coverage by targeting the mistakes that drive most incidents, using real-world, relatable examples drawn from over 10 years of our HIPAA breach reporting.

[View Training](#)

[See Team Pricing](#)

## Talk To Us

The Gold Standard in HIPAA Training by The HIPAA Journal Team

Lessons Cover Emerging Issues Like AI Tools | CEUs & Certificate | Completion Tracking | [HIPAA Training for Individuals](#)**Where do I take HIPAA training for the army?**

HIPAA training for the army is required for all Defense Health Agency military, civilian, and contractor personnel within 30 days of onboarding and annually thereafter. HIPAA training and Privacy Act training (also a requirement for Defense Health Agency personnel) is accessible via the Joint Training System on the Joint Chiefs of Staff website.

**Are the training requirements under HB 300 any different from the HIPAA training requirements?**

The training requirements under HB 300 are different from the HIPAA training requirements inasmuch as new members of a workforce subject to the Texas Medical Records Privacy Act must be trained on policies and procedures within 90 days. The HIPAA training requirements are that new members of the workforce are trained "within a reasonable period of time", so the difference is that HIPAA does not stipulate a timeframe whereas HB 300 does.

HB 300 applies to more types of organizations than HIPAA; and, while the training "requirements" do not differ a great deal, the number of organizations required to provide training is much higher.

**Can Covered Entities be fined for not providing HIPAA training?**

Covered entities can be fined for not providing HIPAA training if it transpires that a violation investigated by HHS' Office for Civil Rights is attributable to a lack of training. Most often, rather than fine a covered entity, HHS' Office for Civil Rights will require the covered entity to follow a Corrective Action Plan which includes monitored and documented training.

**Is it necessary to have HIPAA refresher training whenever new technology is implemented?**

It is necessary to have HIPAA refresher training whenever new technology is implemented if the new technology is being implemented to address a vulnerability or threat to the privacy and security of Protected Health Information. The HIPAA element of the training will be incorporated into the technology element of the training to make both elements more understandable.

**If a material change to a policy occurs, but it only affects a few people, is it necessary for everyone to undergo refresher training?**

If a material change to a policy occurs, but it only affects a few people, it is not necessary for everyone to undergo refresher training unless the material change has a knock-on effect for other members of the workforce. For example, if a covered entity changes its policy for responding to PHI access requests, only those who respond to PHI access requests need to undergo refresher training, but public-facing members of the workforce will also need to know the policy has changed.

**How much is the fine for failing to comply with the HIPAA training requirements?**

The fine for failing to comply with the HIPAA training requirements, if a fine is imposed, varies according to the nature of a subsequent violation attributable to the training failure. Fines for failing to comply with the HIPAA training requirements can also be imposed when no subsequent violation has occurred if the training failure is identified during a compliance audit.

**How does HHS' Office for Civil Rights find out about HIPAA training violations?**

HHS' Office for Civil Rights can find out about HIPAA training violations in a number of ways. The agency can discover a training violation when investigating a complaint from a patient, when investigating a data breach, when investigating a tip-off from a member of the workforce, or when conducting a compliance audit.

**Is it a requirement to provide HIPAA refresher training to the entire workforce when there is a material change to a policy or procedure?**

It is not a requirement to provide HIPAA refresher training to the entire workforce when there is a material change to a policy or procedure unless the material change affects the entire workforce. For example, if there is a change to the content of Business Associate Agreements, only those members of the workforce that handle Business Associate Agreements will have to undergo HIPAA refresher training.

**Why do all members of the workforce have to have HIPAA security and awareness training?**

All members of the workforce have to have HIPAA security and awareness training because all members of the workforce must be aware of cyber risks. Cybercriminals do not necessarily know who has access to PHI stored on a network, so may target every member of the workforce to try to infiltrate the network and move laterally until they find unprotected PHI.

### **Is there a benefit of HIPAA training packages offered by third-party compliance companies?**

There is a benefit of HIPAA training packages offered by third-party compliance companies inasmuch as the packages provide a foundation of HIPAA knowledge. Trainees learn about the basics of HIPAA, why it exists, and what it protects to better prepare them for when they undergo policy and procedure training – which is subsequently more understandable.

For covered entities and business associates, the benefit of HIPAA training packages offered by third-party compliance companies is threefold. The packages prepare new members of the workforce for more advanced policy and procedure training, put security and awareness training into context, and can also be used as the basis for periodic refresher training.

### **Who is responsible for organizing HIPAA training?**

HIPAA compliance officers should be responsible for organizing HIPAA training for members of the workforce, although they don't necessarily have to conduct the training themselves. If, for example, HIPAA security and awareness training involves how to compliantly use a new piece of software, it may be better for a member of the IT team to present the training, although the compliance officer should be in attendance at the presentation.

### **Should a Privacy Officer provide privacy training and a Security Officer provide security training?**

While it would appear to make sense that a Privacy Officer provides privacy training and a Security Officer provides security training, as each Officer should be a specialist in their own field to answer questions, it is not necessary to divide training responsibilities. A lot of crossover exists between privacy and security in HIPAA, so both topics can often be covered together in a training session unless the session is about a specific privacy or security topic.

### **What is an example of a "material change to policies"?**

An example of a material change to policies is when hospitals had to amend policies and procedures to accommodate the change from CMS' Meaningful Use program to the Promoting Interoperability program. If the policy changes affect the way in which ePHI is managed, the personnel involved in managing data for the Promoting Interoperability program should undergo training to avoid there being gaps in their knowledge.

### **Which senior managers should be involved in HIPAA training?**

All senior managers must be involved in HIPAA training, particularly security and awareness training, so they are aware of the impact HIPAA compliance has on operations. It is more practical to involve (for example) CIOs and CISOs in technology training, and CFOs in training that concerns interactions between healthcare organizations and health insurance companies.

### **What is the most important element of HIPAA training?**

The most important element of HIPAA training should be determined by a risk assessment. Thereafter, the "most important element" of HIPAA training will vary on a case-by-case basis and likely vary according to workforce roles. In all cases, workforce members must understand why HIPAA is important and why they are undergoing training in a particular aspect of HIPAA compliance.

### **How long does HIPAA training take?**

How long HIPAA training takes is subject to the amount of content included in the session, the number of people attending the session, and the volume of questions asked during and after the session. Online training modules generally take around five minutes each, so it would take around two hours to complete an online training course, but probably longer in a classroom environment.

### **How often do you have to do HIPAA training?**

How often you have to do HIPAA training depends on factors such as material changes to policies and procedures, risk assessments, and OCR corrective action plans. In addition, as well as maintaining an ongoing security and awareness training program, it is recommended covered entities and business associates provide HIPAA Privacy Rule refresher training at least annually.

### **Why is HIPAA training important?**

HIPAA training is important because, beyond the legal requirement to provide/undergo HIPAA training, it demonstrates to members of the workforce how covered entities and business associates protect patient privacy and ensure the confidentiality, integrity, and availability of

PHI so members of the workforce can perform their duties without violating HIPAA regulations.

### **Who needs HIPAA training?**

Everybody needs HIPAA training if they are a member of a covered entity's or business associate's workforce. This not only means employees have to be trained on HIPAA policies, but also volunteers, students, and contractors who may encounter Protected Health Information in visual, verbal, written, or electronic form. It is also a requirement of the HIPAA Security Rule that all members of the workforce – including senior managers – participate in a security and awareness training program.

### **When does HIPAA training expire?**

HIPAA training does not expire, even though some training organizations issue time-limited certificates of compliance. No training provided in compliance with the HIPAA Privacy and Security Rules has an expiry date unless changes are made to policies and procedures, a risk analysis identifies a need for further training or an individual moves from one covered entity to another where different policies and procedures apply and the new employer has a legal obligation to provide HIPAA training on the different policies and procedures.

### **What kind of HIPAA training do I need to provide to new hires for HIPAA and HITECH?**

The kind of HIPAA training you need to provide to new hires for HIPAA and HITECH depends on whether your organization is a covered entity or business associate.

If your organization is a HIPAA covered entity, you must train new hires on policies and procedures with respect to Protected Health Information and the HIPAA Breach Notification Rule, and provide security and awareness training.

If your organization is a business associate for a covered entity, the training you need to provide for new hires varies according to the service provided to the covered entity. HIPAA Breach Notification training and security and awareness training are mandatory. It may be a condition of a Business Associate Agreement that your organization also provides HIPAA Privacy Rule training to new hires.

### **Why is documentation of HIPAA training necessary?**

The documentation of HIPAA training is necessary for two reasons. First, it demonstrates a covered entity or business associate is complying with the HIPAA training requirements in the event of an audit, inspection, or investigation. Secondly, it records what training has been received by individuals to determine if additional training is required as a consequence of a risk analysis, a policy change, or a promotion.

### **What do you learn during HIPAA training?**

What you learn during HIPAA training depends on the reason for the training being provided. HIPAA training for new employees will likely focus on the basics of HIPAA, policies, and procedures relating to PHI in the workplace, and how to respond to a breach of PHI. Security and awareness training will likely be more focused on best practices for accessing, using, and sharing ePHI online. There may also be occasions when HIPAA training focuses on specific issues identified in a risk assessment or prompted by a patient complaint.

### **What is a HIPAA training certificate?**

A HIPAA training certificate is a third-party accreditation awarded to individuals who pass a HIPAA training course. Often the courses are designed to provide individuals with a basic knowledge of HIPAA so that subsequent training on (for example) policies and procedures or security and awareness is more understandable. HIPAA training certificates can also demonstrate to potential employers that a job candidate has an understanding of the HIPAA rules and regulations.

### **Who is responsible for training students about HIPAA?**

The organization responsible for training students about HIPAA is the covered entity they are under the control of when first exposed to Protected Health Information. Teaching institutions that do not provide medical services to the general public are not considered to be covered entities. Because of this, it may be the case a student does not receive any HIPAA training until after they have graduated and start working as an employee for a healthcare organization.

### **What HIPAA training is required?**

What HIPAA training is required depends on the reason for the training. The basic HIPAA training requirements are that covered entities train members of the workforce on HIPAA-related policies and procedures relevant to their roles and that both covered entities and business associates provide a security awareness and training program. These requirements are not sufficient to prevent the most common types of HIPAA violations, and it is recommended all businesses supplement the minimum requirements with frequent refresher training.

## HIPAA Training That Lowers Breach Risk

Our training goes beyond basic rule coverage by targeting the mistakes that drive most incidents, using real-world, relatable examples drawn from over 10 years of our HIPAA breach reporting.

[View Training](#)

The Gold Standard in HIPAA Training  
by The HIPAA Journal Team

[HIPAA Training for Individuals](#)

## HIPAA Training That Lowers Breach Risk

Our training goes beyond basic rule coverage by targeting the mistakes that drive most incidents, using real-world, relatable examples drawn from over 10 years of our HIPAA breach reporting.

[View Training](#)

[See Team Pricing](#)

[Talk To Us](#)

The Gold Standard in HIPAA Training by The HIPAA Journal Team

[Lessons Cover Emerging Issues Like AI Tools](#) | [CEUs & Certificate](#) | [Completion Tracking](#) | [HIPAA Training for Individuals](#)

**Author:** [Steve Alder](#) is the editor-in-chief of The HIPAA Journal. Steve is responsible for editorial policy regarding the topics covered in The HIPAA Journal. He is a specialist on healthcare industry legal and regulatory affairs, and has 10 years of experience writing about HIPAA and other related legal topics. Steve has developed a deep understanding of regulatory issues surrounding the use of information technology in the healthcare industry and has written hundreds of articles on HIPAA-related topics. Steve shapes the editorial policy of The HIPAA Journal, ensuring its comprehensive coverage of critical topics. Steve Alder is considered an authority in the healthcare industry on HIPAA. The HIPAA Journal has evolved into the leading independent authority on HIPAA under Steve's editorial leadership. Steve manages a team of writers and is responsible for the factual and legal accuracy of all content published on The HIPAA Journal. Steve holds a Bachelor's of Science degree from the University of Liverpool. You can connect with Steve via [LinkedIn](#) or email via [stevealder\(at\)hipaajournal.com](mailto:stevealder(at)hipaajournal.com)



**HIPAA Training**  
**That Lowers Breach Risk**

Our HIPAA training goes beyond basic rule coverage by targeting the mistakes that drive most incidents, using real-world, relatable examples drawn from over ten years of our HIPAA breach reporting.

[View The HIPAA Journal Training](#)

**The Gold Standard in HIPAA Training**  
by The HIPAA Journal Team

CEUs & Certificates | [Completion Tracking](#)

[View HIPAA Training for Individuals](#)



---

### About The HIPAA Journal

The HIPAA Journal is the leading source of information on the Health Insurance Portability and Accountability Act (HIPAA), providing the best-available HIPAA Training and news coverage of regulatory developments, enforcement actions, data breaches, and best practices for compliance. The HIPAA Journal's HIPAA training is produced by a team of HIPAA experts, each with over a decade of expertise, who are deeply committed to high-quality HIPAA education.

#### Subscribe To Weekly News Digest

HIPAA News  
Regulatory Changes  
Breach News  
HITECH News  
HIPAA Advice

Sign Me Up

Unsubscribe Anytime

### Most Read Posts

- ▶ [HIPAA Training Buyer's Guide](#)
- ▶ [HIPAA Training for Business Associates](#)
- ▶ [How to Choose HIPAA Compliance Software](#)

- ▶ [HIPAA Training Requirements](#)
- ▶ [How to Become HIPAA Compliant](#)

|                                                                   |
|-------------------------------------------------------------------|
| <p><b>Get The FREE<br/>HIPAA Compliance Checklist</b></p>         |
| <p>Immediate Delivery of Checklist Link To Your Email Address</p> |
| <p><input type="text"/></p>                                       |
| <p><a href="#">Get Free Checklist</a></p>                         |
| <p><b>Get The FREE<br/>HIPAA Compliance Checklist</b></p>         |
| <p>Immediate Delivery of Checklist Link To Your Email Address</p> |
| <p>Work Email *</p>                                               |
| <p><input type="text"/></p>                                       |
| <p><a href="#">Get Free Checklist</a></p>                         |

[Submit Press Releases](#)

[Editorial Policy](#)

[Mission Statement](#)

[Careers](#)

[Advertise](#)

[Contact Us](#)

[Privacy Policy](#)

[Terms & Conditions](#)

[Trademark Policy](#)

[Accessibility Statement](#)

[Cookie Policy](#)

[Site Map](#)

© Copyright 2014-2026

® The HIPAA Journal is a registered trademark  
All Rights Reserved